CONFIDENTIAL

Bank Portal Authentication

Signing in with a portal password and with single sign-on

Appro Onboarding Solutions FZ-LLC
Prepared by: Appro Product
Date: 28/10/2026
Version 1.0 · Draft for review

About this document

This document explains, for the bank's business, operations and IT teams, how staff sign in to the Bank Portal: with a portal password, or with single sign-on through the bank's own identity provider. It sets out what each person sees, the rules behind each outcome, what the bank controls, and what to put in place before single sign-on is switched on.

It describes the agreed product behaviour. Screens are shown in section order and listed in Appendix B.

Contents

1. Executive summary
2. Key terms
3. How sign-in works
4. Signing in with a portal password
5. Signing in with single sign-on
6. Managing single sign-on: Sign-in Settings
7. Accounts from the bank's directory
8. Security policy by account type
9. Roles and responsibilities
10. Before you switch on single sign-on
11. Planned enhancements
Appendix A. Messages
Appendix B. Screenshot index

1. Executive summary

The Bank Portal offers two ways to sign in. Every bank has the **portal password** route. A bank that connects its own identity provider can switch on **single sign-on** for the staff in its directory. Five rules govern both routes.

1. **One setting per bank.** Single sign-on is On or Off for the whole bank, never per user.
2. **The account decides the route.** Portal accounts sign in with a password. Directory accounts sign in with single sign-on. The portal reads the account before it evaluates any password, and tells a person who pressed the wrong button which one to use.
3. **Password rules never block single sign-on.** Expiry, history and lockout apply to portal passwords only. A directory account has no portal password, so none of these rules can stop it.
4. **Every change needs two people.** Turning single sign-on on or off, and changing the connection details, both go through Maker-Checker approval.
5. **The login page does not confirm that an account exists.** A wrong password and an unknown email return the same message, on the same field, in the same time.

At a glance

	Portal password	Single sign-on
Who uses it	Portal accounts, created by the bank's Super Admin through Add User	Directory accounts, created automatically from the bank's directory
Button on the login page	Login	Login with SSO — shown only while single sign-on is On
How identity is proven	Password, then a one-time code sent to the registered email	At the bank's identity provider, including its multi-factor authentication if the bank has set it up
Password rules	Portal password policy (section 4.4)	The bank's own directory policy
Who controls access	Bank Super Admin, in the portal	Bank directory administrator; entitlements by the Super Admin in the portal
Availability	Always	While the bank has single sign-on switched On

2. Key terms

Term	Meaning in this document
Portal account	A user created in the portal by the bank's Super Admin. Signs in with a portal password. Shown with Source = Portal.
Directory account	A user created automatically from the bank's directory. Signs in with single sign-on and has no portal password. Shown with Source = Directory.
Identity provider	The bank's own sign-in service, which holds its staff directory and checks their corporate credentials.
Single sign-on (SSO)	Signing in to the portal with corporate credentials, verified by the bank's identity provider rather than by the portal.
Sign-in Settings	The portal screen where the bank switches single sign-on On or Off and maintains the connection to its identity provider.
Maker / Checker	The person who submits a change, and the different person who approves or rejects it.
Status	Active or Inactive. The only gate for any sign-in. A password event — expiry, lockout — never changes it.
Entitlements	What a user may see and do in the portal: channel, approval level, product type, access to personal data.

3. How sign-in works

The portal reads the account record first, then decides. Figure 1 shows every combination of account and button, and what the person sees.

FIGURE 1

What each person sees, by account and by button

	Login email + password	**Login with SSO** shown only while single sign-on is On
PORTAL ACCOUNT		
Password correct and valid	**Signs in** after the email one-time code	**Refused** Not registered
Wrong password	**Refused** "Your Email or Password is incorrect!"	**Refused** Not registered
Password expired or account locked	**Told how to recover** Reset through "Forgot password?"	**Refused** Not registered
DIRECTORY ACCOUNT		
Single sign-on On	**Sent to the right route** Told to select "Login with SSO"	**Signs in** No portal password rule is checked
Single sign-on Off	**Told why** Single sign-on is switched off — contact the administrator	**Button hidden** A late return from the identity provider is told it is off
NOT IN THE PORTAL		
Email unknown	**Refused** Same message and timing as a wrong password	**Refused** Not registered

● Signs in ● Told which way to go ○ Refused

What the page discloses, and what it does not

- A person whose email is unknown, or who enters the wrong password for a portal account, gets the same message — identical text, field and timing. The page never confirms that an account exists.
- A person who enters an email that belongs to a directory account is told to use single sign-on, or that single sign-on is switched off. This is deliberate: it sends staff to the right route instead of leaving them at a generic refusal.
- The two buttons never read each other. Login with SSO never reads the email or password typed on the page, and the password route never calls the bank's identity provider.

4. Signing in with a portal password

For portal accounts. Two factors protect every sign-in: the password, then a one-time code sent to the registered email address.

FIGURE 2

Signing in with a portal password

1. **Enter email and password**
   Select **Login**. The password can be shown or hidden.
2. **The portal checks the account**
   Account type and status first, then the password.
3. **One-time code by email**
   6 digits, valid for 10 minutes. **Resend OTP** appears after a 60-second countdown.
4. **Verify and Login**
   The correct code opens the landing screen.
5. **Session**
   Signed out after 5 minutes of inactivity, with a 30-second warning.

WHEN THE ATTEMPT DOES NOT GO THROUGH

- **Wrong password or unknown email**
  Same message in both cases — the page never reveals whether an email exists.
- **5 failed attempts within an hour**
  The account is locked. Fewer failures clear the next hour.
- **Password expired or locked**
  Told to reset the password through "Forgot password?".
- **Account signs in with single sign-on**
  Told to select "Login with SSO" — or that single sign-on is off.
- **Wrong or expired code**
  Asked to try again. Resend issues a new code and cancels the old one.
- **More than 5 wrong codes in a day**
  Verify and Resend are disabled for 1 hour, with a countdown.
- **Account inactive**
  Told the account is inactive and to contact the administrator.
- **Invitation not yet used**
  Told no password has been set, and to check the invitation email.

4.1 The login page

Component	Behaviour
Email Address	Mandatory. The account's registered email.
Password	Mandatory. Masked by default; the eye icon shows or hides it.
Forgot Password	Starts a password reset (section 4.5).

Component	Behaviour
Login	Validates the email and password, then sends the one-time code.
Login with SSO	Shown only while the bank has single sign-on switched On. Appears or disappears on the next page load after approval, with no manual refresh.

Screenshot 1

Login page — password route and Login with SSO

4.2 One-time code

- A unique 6-digit code is generated and emailed to the registered address after the password is accepted.
- The code is valid for **10 minutes**. A 60-second countdown runs before **Resend OTP** becomes available.
- Resending issues a new code and cancels the previous one.
- A wrong or expired code is refused, and the person is asked to try again.
- After **more than 5 wrong codes in a row in a day**, Verify and Login and Resend OTP are disabled for **1 hour**, with a countdown shown under the code field.

Screenshot 2

One-time code screen

4.3 Failed attempts and lockout

- **5 failed sign-in attempts within an hour** lock the account.
- Fewer than 5 failures are cleared at the start of the next hour.
- Lockout and expiry are recorded against the password only. They never change the account's Status, and they never affect single sign-on.

4.4 Password policy

Applies to portal accounts only.

Rule	Requirement
Length	At least 10 characters
Composition	At least one uppercase letter (A–Z), one lowercase letter (a–z), one number and one special character
Not allowed	Dictionary words · repetitive characters such as “aaaaaaa” or “1234abcd” · context-specific terms such as the company, service or username
Expiry	60 days
Reuse	None of the last 6 passwords
Lockout	5 failed attempts
Dormant accounts	Disabled after 30 days without a sign-in
Protection	Encrypted in transit and hashed when stored
Session	Signed out after 5 minutes of inactivity

4.5 Expired or locked password

The person is told their password has expired and to reset it using “Forgot password?”. They are not shown the generic refusal, so they know the way back in.

Screenshot 3

Portal account with an expired password

4.6 Forgot password

- The page always answers “If this username exists, a reset email has been sent.” — whatever was entered.
- A directory account has no portal password, so no reset email is sent for it.

4.7 Session and logout

- After **4 minutes 30 seconds** without activity a warning counts down 30 seconds. **Keep working** continues the session; **Log out** ends it at once. At zero the person is signed out.
- After an automatic sign-out the person signs in again. No previous session data is kept.

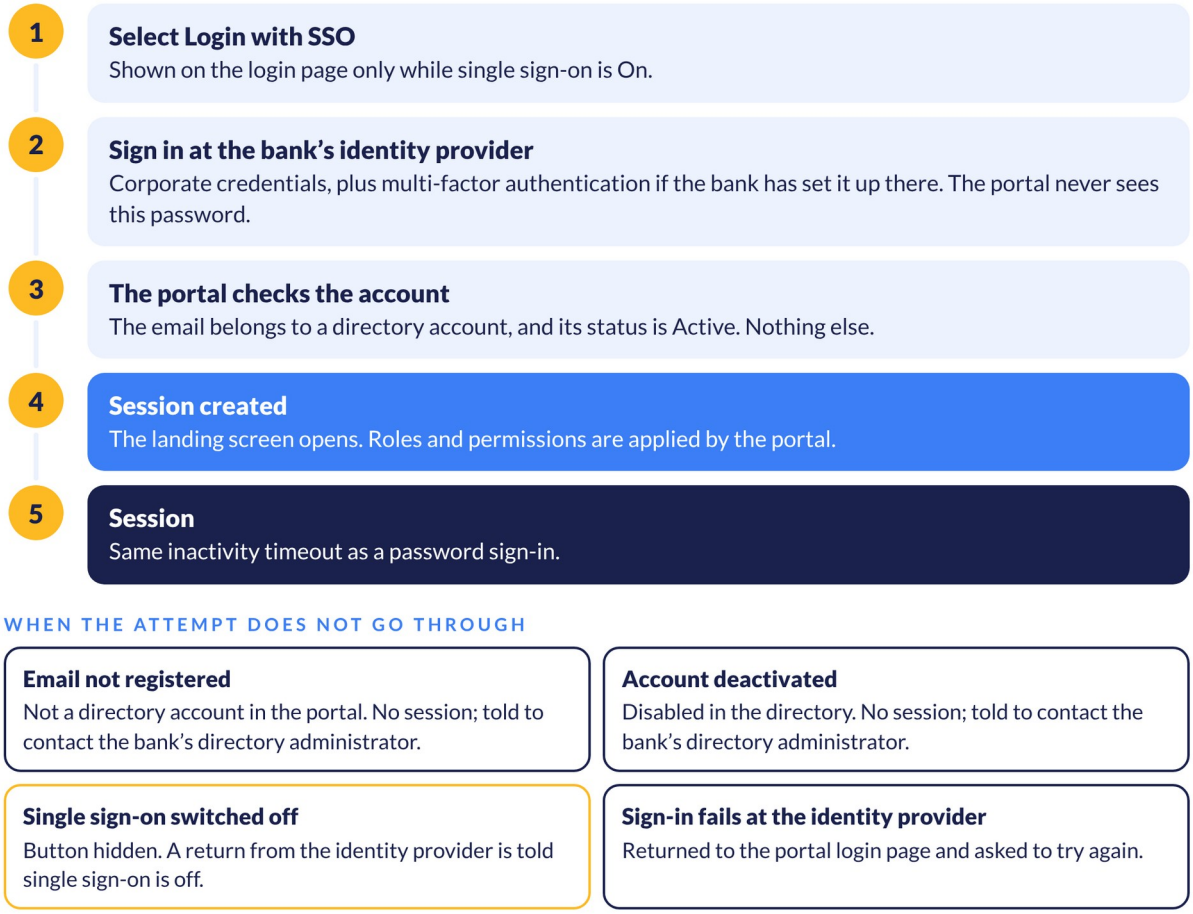
- Log Out in the left menu asks “Are you sure you want to Logout?”. Cancel keeps the session; Logout returns to the login page.

5. Signing in with single sign-on

For directory accounts, while the bank has single sign-on switched On. The person proves who they are to the bank's own identity provider. The portal never sees or stores their corporate password.

FIGURE 3

Signing in with single sign-on



5.1 What the portal checks

Exactly two things: that the email belongs to a **directory account**, and that its Status is **Active**. Nothing about a portal password is read — expiry, history and lockout cannot block or interrupt a single sign-on.

5.2 A directory account on the password route

If a directory account enters its email and a password on the Login form, the portal does not evaluate the password. It tells the person: "This account now signs in with single sign-on. Select "Login with SSO" to continue."

Screenshot 4

Directory account on the password route

5.3 When single sign-on is switched off

- Login with SSO is hidden.
- A directory account on the password route is told: “Single sign-on is currently switched off for your organisation. Please contact your administrator.”
- There is **no password fallback**. Directory accounts cannot sign in at all until single sign-on is switched back On. Their records and roles are kept.
- Portal accounts are unaffected.

Screenshot 5

Login while single sign-on is switched off

6. Managing single sign-on: Sign-in Settings

Navigation: Users Management → Sign-in Settings. **Permissions:** View Sign-in Settings; Edit Sign-in Settings (Maker).

One setting per bank. The screen holds the single sign-on switch and the connection to the bank's identity provider. There is no per-user sign-in method.

6.1 The screen

Component	What it shows
Single sign-on	The On / Off switch for the whole bank. Default for a new bank: Off. Locked while a request is waiting for approval.
Status line	Under the switch: On or Off, then who last changed it and when (DD/MM/YYYY HH:MM). Replaced by "Pending Checker approval" while a request is open.
Connection status	Connected when On · Paused when Off · Pending Checker approval while a request is open.
Tenant ID	From the bank's identity provider. Must be a valid identifier before it can be submitted.
Client ID	From the bank's identity provider. Same validation as Tenant ID.
Redirect URI	Generated by Appro. The bank registers it with its identity provider. Read-only, with a copy button.
Client secret	Write-only. Stored encrypted and never displayed after saving — the screen shows only that it is set, when and by whom. Minimum 8 characters; leave blank to keep the current secret.

Screenshot 6

Sign-in Settings — view

Screenshot 7

Connection details — edit

6.2 Making a change

- **Switch:** operating the switch opens a confirmation. It asks for an optional reason, which is passed to the Checker. Nothing changes on the Maker's click.
- **Turning Off** adds a warning: "Staff who sign in with single sign-on will not be able to sign in at all until it is turned on again — they have no password to fall back to."
- **Connection details:** Edit opens the values. Submit for approval is enabled only when at least one value has changed and every changed value is valid. An invalid value never reaches the Checker.
- On submission the Maker sees "Your request for updated information is created successfully!" and the screen shows the pending state.

Screenshot 8

Connection details — invalid value

Screenshot 9

Turn off single sign-on — confirmation

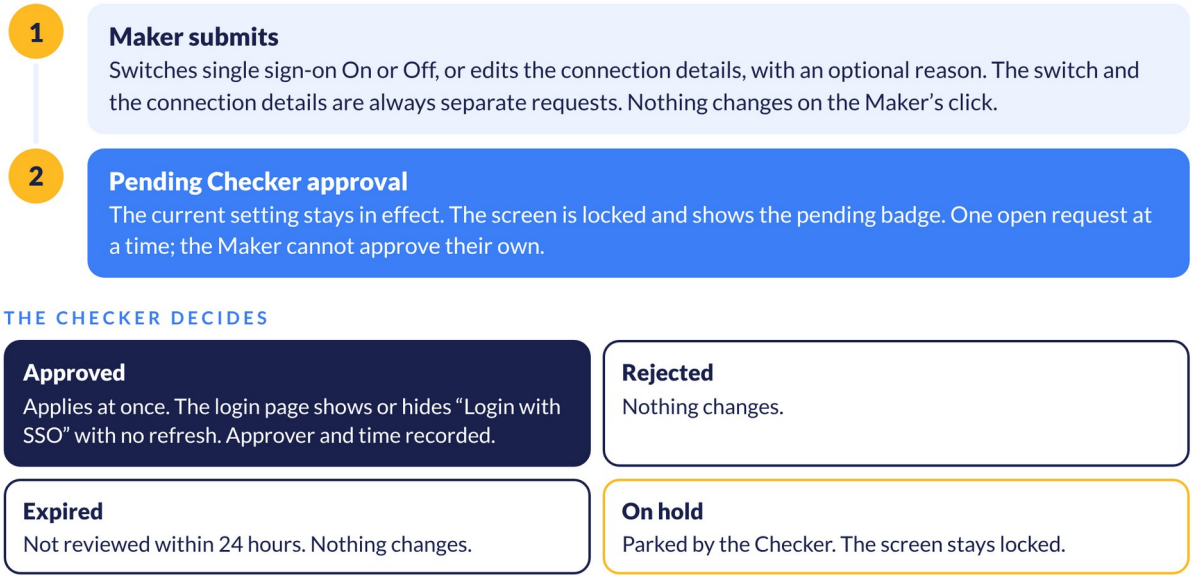
Screenshot 10

Sign-in Settings — pending Checker approval

6.3 Approval

FIGURE 4

Every change to Sign-in Settings needs a second person



The Checker sees the request summary, the Maker's reason, and each changed value as **NEW** beside the **CURRENT** value. The client secret is masked on both lines — its value is never shown to anyone. Unchanged connection values are listed so the Checker sees the full connection. Nothing on the review screen is editable.

Screenshot 11

Request details — single sign-on switch

Screenshot 12

Request details — connection details

6.4 What On and Off mean

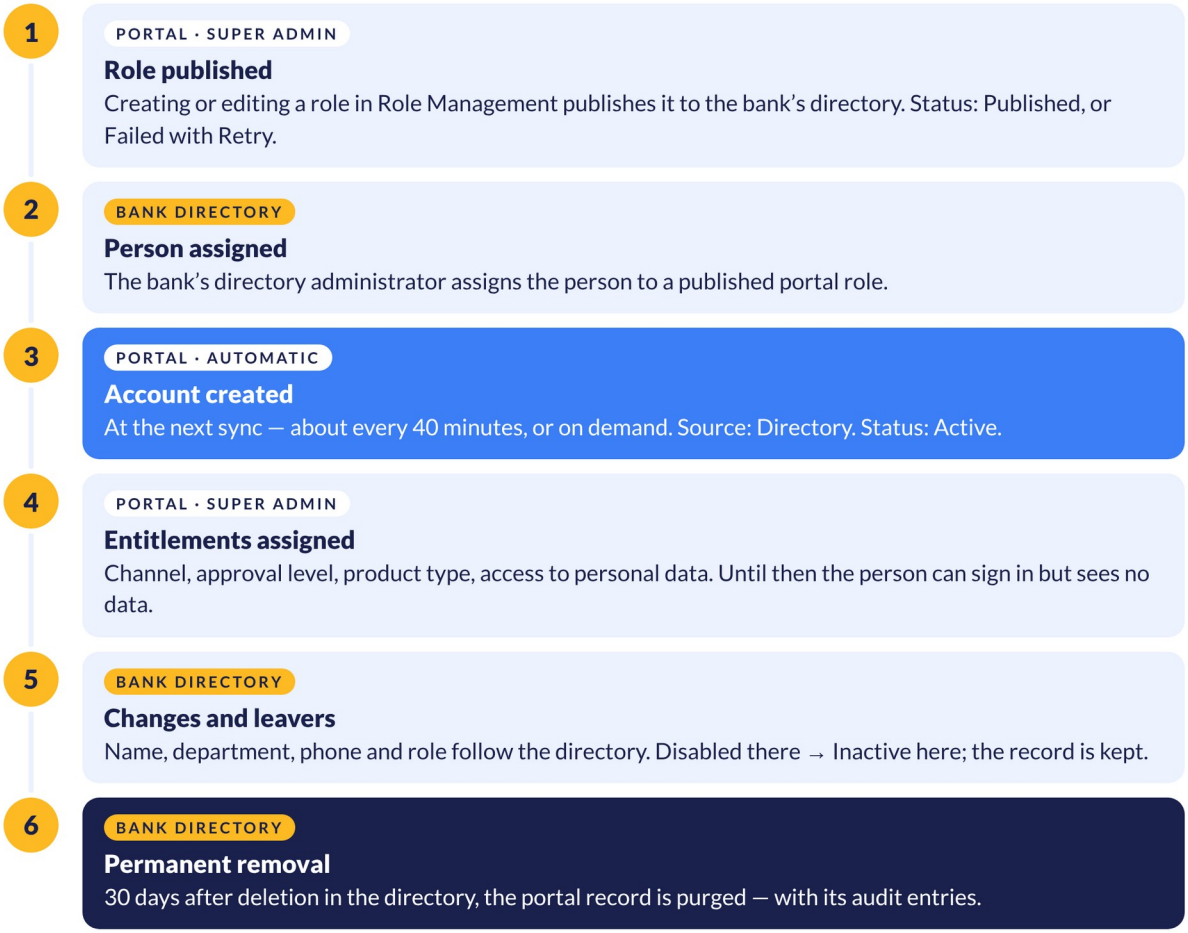
	On	Off
Login with SSO	Shown	Hidden
Directory accounts	Sign in with single sign-on	Cannot sign in. Records and roles kept.
Portal accounts	Sign in with a password	Sign in with a password
Directory sync and role publishing	Running	Paused
Switching back On	—	Access returns at once. Directory sync resumes at its next cycle.

7. Accounts from the bank's directory

The bank's directory owns who a person is. The portal owns what they may see and do.

FIGURE 5

A directory account, from first role to removal



7.1 Roles

- Creating or editing a role in Role Management publishes it to the bank's directory automatically — there is no separate publish step.
- Each role shows **Published** with a timestamp, or **Failed** with a **Retry** button.
- A published role that still has users assigned cannot be deleted. Unassign all users first.
- Manage portal roles in the portal only. The portal keeps the bank's directory in step with its own list of roles.

Screenshot 13

Role Management — publish status

7.2 Entitlements

A new directory account can sign in at once but sees no data until the Super Admin assigns entitlements. Nothing is inherited automatically from the role.

Entitlement	Default for a new directory account
Approval Level	None
Max Limit Approved Amount	0
Channel	None — no access to channel-based screens
Product Type	None
View PII Data	Not allowed

The fields offered follow the person's department, as held in the directory: **Credit** adds Max Limit Approved Amount; **Sales** adds Staff ID; every other department uses the standard fields. A role change from the directory replaces the role but keeps channels and entitlements.

7.3 What the bank can change on each account type

	Directory account	Portal account
Name, Department, Phone, Email, Role, Lock Status	Read-only — follow the directory	Editable
Approval Level, Max Limit, Channel, Product Type, View PII Data	Editable — Edit Entitlements	Editable
Edit and Delete	Hidden	Available
Created by	Directory sync	Super Admin, through Add User

Screenshot 14

User Details — directory account

7.4 User Management list

- A **Source** column shows Directory or Portal, with filters All / Directory / Portal. Export includes Source.
- Add User is always available and always creates a portal account, whatever the single sign-on setting.
- Deactivated directory accounts stay in the list and in search, because the directory may reactivate them.

Screenshot 15

User Management list — Source column

7.5 Leavers and removal

- A person disabled in the directory becomes **Inactive** in the portal at the next sync and cannot sign in. The record is kept.
- If the directory reactivates them, they return to **Active** with channels and entitlements intact.
- A person deleted in the directory is **permanently purged** from the portal 30 days later.
- **Purging removes the person's audit trail entries.** The bank's compliance team must accept this before single sign-on is switched on.

8. Security policy by account type

Policy	Portal account	Directory account
Password complexity, expiry, history	Enforced by the portal	Not applicable — no portal password. Set by the bank's directory.
Failed sign-in lockout	Enforced by the portal	Not applicable — handled by the bank's identity provider
Dormant account disable	Enforced by the portal	Not applicable — status follows the directory
Multi-factor authentication	One-time code by email	The bank's identity provider, if configured there
Session timeout	Enforced by the portal	Enforced by the portal — same rules
Roles and permissions	Enforced by the portal	Enforced by the portal — role from the directory, permissions in the portal

9. Roles and responsibilities

Activity	Bank directory administrator	Bank Super Admin	Bank Checker	Appro
Register the portal with the identity provider, including the Redirect URI	Does	—	—	Generates the Redirect URI
Enter and maintain Tenant ID, Client ID, client secret	Provides values	Submits	Approves	—
Switch single sign-on On or Off	—	Submits	Approves	—
Set up the directory sync connection	—	—	—	Does, at onboarding
Create and edit portal roles	—	Does	—	—
Assign staff to portal roles	Does	—	—	—
Assign entitlements to directory accounts	—	Does	—	—
Create portal accounts	—	Does, through Add User	—	—
Disable and remove leavers	Does	—	—	—

Activity	Bank directory administrator	Bank Super Admin	Bank Checker	Appro
Multi-factor authentication for single sign-on	Does, in the identity provider	—	—	—

10. Before you switch on single sign-on

1. **Compliance acceptance.** The bank's compliance team accepts that a permanently removed directory account takes its audit trail entries with it (section 7.5).
2. **Redirect URI registered.** The bank's IT team registers the Redirect URI shown on Sign-in Settings with the identity provider.
3. **Connection approved.** Tenant ID, Client ID and client secret are entered by a Maker and approved by a Checker.
4. **Directory sync in place.** Appro has completed the directory sync connection for the bank.
5. **Roles and people ready.** Portal roles are published, staff are assigned to them in the directory, and entitlements are assigned in the portal.
6. **Administrators on portal accounts.** Keep the bank's Super Admin and Checker as portal accounts. Portal accounts are unaffected by the single sign-on switch, so administration stays possible if single sign-on is switched off or the identity provider is unavailable.
7. **Staff told.** Directory staff use Login with SSO. They have no portal password, and Forgot password does not apply to them.

11. Planned enhancements

The following are agreed in scope for a later release and are **not yet available**. Timing will be confirmed separately.

Enhancement	What changes
One email, one sign-in method	A portal account whose email appears in the bank's directory converts to single sign-on at its first successful single sign-on. The portal password is removed; roles, entitlements and history are kept.
Break-glass accounts	The bank's Super Admin and Checker accounts created at onboarding always keep password sign-in, even if the directory holds the same email — so the bank can never be locked out of the portal.
Sign-in method on screen	User Management shows each account's sign-in method and portal password status, in the list, on User Details and in the export.
Add User checks	Add User refuses an email that already signs in with single sign-on, or that exists in the bank's directory.

Appendix A. Messages

Sign-in messages appear in line under the field, with the field outlined in red. No pop-ups.

Password route

Situation	Message
Wrong password, or email unknown	"Your Email or Password is incorrect!"
Password expired or account locked	"Your password has expired. Reset it using "Forgot password?" to continue."
Invitation sent, password never set	"No password has been set yet. Check your email for the invitation link."
Account inactive	"Username is inactive. Please contact the Administrator!"
Directory account, single sign-on On	"This account now signs in with single sign-on. Select "Login with SSO" to continue."
Directory account, single sign-on Off	"Single sign-on is currently switched off for your organisation. Please contact your administrator."
Wrong one-time code	"The OTP verification code is not correct, please try again!"
Expired one-time code	"The OTP verification code is expired, please try again!"
More than 5 wrong codes in a day	"You have entered the wrong OTP Verification Code more than 5 times in a row of a day, please try again later {countdown}!"
Forgot password, any input	"If this username exists, a reset email has been sent."
Manual logout	"Are you sure you want to Logout?"

Single sign-on route

Situation	Message
Email not registered as a directory account	"User is not registered. Contact your bank's directory administrator."
Sign-in returns while single sign-on is Off	"Single sign-on is currently switched off for your organisation. Please contact your administrator."

Administration

Situation	Message
Sign-in Settings request submitted	"Your request for updated information is created successfully!"
Role published	"Role '{roleName}' published to directory successfully."
Role publish failed	"Could not publish role '{roleName}' to the directory. Please try again or contact support."
Service check failed after publishing	"Service verification failed. Directory users may not receive this role until resolved."
Delete a role that has users	"Cannot delete role '{roleName}' — {N} users assigned. Unassign all users first."
Entitlements saved	"User entitlements updated successfully."

Appendix B. Screenshot index

#	Screen	Section
1	Login page — password route and Login with SSO	4.1
2	One-time code screen	4.2
3	Portal account with an expired password	4.5
4	Directory account on the password route	5.2
5	Login while single sign-on is switched off	5.3
6	Sign-in Settings — view	6.1
7	Connection details — edit	6.1
8	Connection details — invalid value	6.2
9	Turn off single sign-on — confirmation	6.2
10	Sign-in Settings — pending Checker approval	6.2
11	Request details — single sign-on switch	6.3
12	Request details — connection details	6.3
13	Role Management — publish status	7.1
14	User Details — directory account	7.3
15	User Management list — Source column	7.4

End of document

Prepared by Appro Product | Appro Onboarding Solutions FZ-LLC
28/10/2026